

ZAP by Checkmarx Scanning Report

Generated with  ZAP on Sat 16 May 2026, at 15:35:33

ZAP Version: 2.16.1

ZAP by Checkmarx

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)

- [Alert Counts by Alert Type](#)
- [Alerts](#)
 - [Risk=Medium, Confidence=High \(1\)](#)
 - [Risk=Medium, Confidence=Medium \(1\)](#)
 - [Risk=Medium, Confidence=Low \(1\)](#)
 - [Risk=Low, Confidence=High \(2\)](#)
 - [Risk=Low, Confidence=Medium \(2\)](#)
 - [Risk=Informational, Confidence=Medium \(2\)](#)
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- `http://127.0.0.1:5000`

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: `High`, `Medium`, `Low`, `Informational`

Excluded: `None`

Confidence levels

Included: `User Confirmed`, `High`, `Medium`, `Low`

Excluded: `User Confirmed`, `High`, `Medium`, `Low`, `False Positive`

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	1 (11.1%)	1 (11.1%)	1 (11.1%)	3 (33.3%)
	Low	0 (0.0%)	2 (22.2%)	2 (22.2%)	0 (0.0%)	4 (44.4%)
	Informational	0 (0.0%)	0 (0.0%)	2 (22.2%)	0 (0.0%)	2 (22.2%)
	Total	0 (0.0%)	3 (33.3%)	5 (55.6%)	1 (11.1%)	9 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High	Medium	Low (>= Information	al)
		(= High)	(>= Medium)	(>= Low)	
Site	http://127.0.0.1:5000	0	3	4	2
		(0)	(3)	(7)	(9)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Total		9

Alert type	Risk	Count
Absence of Anti-CSRF Tokens	Medium	4 (44.4%)
Content Security Policy_(CSP) Header Not Set	Medium	6 (66.7%)
Missing Anti-clickjacking Header	Medium	4 (44.4%)
Cookie without SameSite Attribute	Low	2 (22.2%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	7 (77.8%)
X-Content-Type-Options Header Missing	Low	4 (44.4%)
ZAP is Out of Date	Low	1 (11.1%)
Tech Detected - Flask	Informational	1 (11.1%)
Total		9

Alert type	Risk	Count
Tech Detected - Python	Informational	1 (11.1%)
Total		9

Alerts

Risk=Medium, Confidence=High (1)

<http://127.0.0.1:5000> (1)

[Content Security Policy \(CSP\) Header Not Set](#) (1)

► GET <http://127.0.0.1:5000/robots.txt>

Risk=Medium, Confidence=Medium (1)

<http://127.0.0.1:5000> (1)

[Missing Anti-clickjacking Header](#) (1)

► GET http://127.0.0.1:5000/login

Risk=Medium, Confidence=Low (1)

http://127.0.0.1:5000 (1)

Absence of Anti-CSRF Tokens (1)

► GET http://127.0.0.1:5000/login

Risk=Low, Confidence=High (2)

http://127.0.0.1:5000 (2)

Server Leaks Version Information via "Server" HTTP Response Header Field (1)

► GET http://127.0.0.1:5000

ZAP is Out of Date (1)

► GET http://127.0.0.1:5000

Risk=Low, Confidence=Medium (2)

<http://127.0.0.1:5000> (2)

Cookie without SameSite Attribute (1)

► POST <http://127.0.0.1:5000/login>

X-Content-Type-Options Header Missing (1)

► GET <http://127.0.0.1:5000/login>

Risk=Informational, Confidence=Medium (2)

<http://127.0.0.1:5000> (2)

Tech Detected - Flask (1)

► GET <http://127.0.0.1:5000/login>

Tech Detected - Python (1)

► GET <http://127.0.0.1:5000/login>

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Absence of Anti-CSRF Tokens

Source	raised by a passive scanner (Absence of Anti-CSRF Tokens)
CWE ID	352
WASC ID	9
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html ▪ https://cwe.mitre.org/data/definitions/352.html

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693

WASC ID 15

Reference

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>
- https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
- <https://www.w3.org/TR/CSP/>
- <https://w3c.github.io/webappsec-csp/>
- <https://web.dev/articles/csp>
- <https://caniuse.com/#feat=contentsecuritypolicy>
- <https://content-security-policy.com/>

Missing Anti-clickjacking Header

Source raised by a passive scanner ([Anti-clickjacking_Header](#))

CWE ID [1021](#)

WASC ID 15

Reference ■ <https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options>

Cookie without SameSite Attribute

Source raised by a passive scanner ([Cookie without SameSite Attribute](#))

CWE ID [1275](#)

WASC ID 13

Reference ■ <https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site>

Server Leaks Version Information via "Server" HTTP Response Header Field

Source raised by a passive scanner ([HTTP Server Response Header](#))

CWE ID [497](#)

WASC ID 13

Reference ■ <https://httpd.apache.org/docs/current/mod/core.html#servertoken>
[s](#)

- [https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552\(v=pandp.10\)](https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10))
- <https://www.troyhunt.com/shhh-dont-let-your-response-headers/>

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security-Headers

ZAP is Out of Date

Source	raised by a passive scanner (ZAP is Out of Date)
CWE ID	1104

WASC ID 45

Reference ■ <https://www.zaproxy.org/download/>

Tech Detected - Flask

Source raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)

WASC ID 13

Reference ■ <https://github.com/pallets/flask/>

Tech Detected - Python

Source raised by other tools/functionalities in ZAP (for example, fuzzer, HTTPS Info add-on, custom scripts...) (plugin ID: 10004)

WASC ID 13

Reference ■ <https://python.org>